

[← TODAS AS EDIÇÕES](#)

#23 08 JUN 2026 20 min de leitura

WordPress sangrando, SD-WAN sem patch, supply chain npm e IA acelerando o ataque

ZERO-DAY

SUPPLY CHAIN

WORDPRESS

DATA BREACH

AI SECURITY

5

CRÍTICAS

7

ALTAS

3

MÉDIAS

Semana curta desde a última edição, mas a internet não respeita calendário editorial, porque claro que não. O cardápio veio com WordPress explorado, SD-WAN da Cisco sem patch, Serv-U no KEV, npm cuspiendo infostealer e engenharia social fingindo ser suporte de TI.

Na parte de IA, o recado ficou menos “futuro distante” e mais “isso já está no pipeline”: ransomware usando agentes para acelerar evasão, pesquisa autônoma achando bug antigo e scraping para IA usando dispositivo doméstico como infraestrutura.

Segurança geral

01

CRÍTICO

Botnet / IoT

COXMO transforma roteadores DD-WRT em exército DDoS com faxina de concorrente

A Fortinet detalhou uma nova variante do botnet Gafgyt chamada COXMO mirando firmware DD-WRT e outros dispositivos em várias arquiteturas — ARM, MIPS, PowerPC, SuperH, x86 e afins. A entrega passa pela CVE-2021-27137, uma falha de buffer overflow explorável sem autenticação para execução de código.

O tempero ruim é que o malware não só infecta: ele baixa scanner em Python, tenta SSH/Telnet com credenciais fracas, detecta arquitetura, cria persistência em cron e ainda mata malware concorrente, ferramentas de red team e serviços que atrapalhem sua operação. É botnet fazendo limpeza de terreno antes de montar barraca. Um encanto, se você odeia a internet.

No fim, o objetivo continua clássico: DDoS. Mas a modularidade, os 19 métodos de ataque e a capacidade de lateralizar em IoT mostram que “roteador esquecido” continua sendo infraestrutura gratuita para criminoso.

O que fazer: Atualizar DD-WRT e firmware de borda, trocar credenciais padrão, desabilitar acesso remoto desnecessário e procurar persistência em /tmp, /var/tmp, /dev/shm e cron jobs suspeitos.

Fontes: BleepingComputer · Fortinet

02

CRÍTICO

Extorsão / Social Engineering

Silent Ransom Group mira escritórios de advocacia com falso suporte de TI

Mandiant e FBI acenderam o alerta para a Silent Ransom Group, também rastreada como UNC3753, Luna Moth e Chatty Spider, mirando escritórios de advocacia e serviços profissionais nos EUA. O ataque começa sem malware

glamouroso: e-mail com tema de fatura, ligação de “suporte de TI” e convencimento para a vítima entrar em sessão remota.

O grupo usa Teams, Zoom, Quick Assist ou Terminal Services para conduzir a vítima, instala ferramentas como AnyDesk, Zoho Assist, Bomgar ou SuperOps e parte para roubo de documentos sensíveis. Segundo a Mandiant, em muitos casos a extorsão chega até 30 minutos depois de os atacantes saírem do ambiente. Rápido, sujo e eficiente — o trio que ninguém quer no incidente.

Legal é alvo óbvio porque concentra contrato, M&A, segredo comercial, dados financeiros e informação que causa pânico reputacional. É o tipo de vítima que o criminoso acha que vai pagar para o problema ficar quieto.

O que fazer: Criar procedimento rígido para suporte remoto, bloquear RMM não aprovado, treinar vishing/callback phishing, exigir verificação fora de banda e monitorar exfiltração via WinSCP/Rclone.

Fontes: BleepingComputer · Google Cloud / Mandiant

03

CRÍTICO

WordPress / RCE

Everest Forms Pro explorado para virar dono de site WordPress

Atacantes estão explorando a CVE-2026-3300 no Everest Forms Pro, plugin comercial de formulários para WordPress. A falha afeta versões 1.9.12 e anteriores e permite execução arbitrária de código sem autenticação por causa da função de cálculo complexo usando eval() com entrada de formulário mal escapada.

O abuso visto pela Wordfence cria uma conta administradora maliciosa — incluindo o usuário “diksimarina” nos exemplos — e daí o resto é o de sempre: plugin malicioso, webshell, banco privado exposto e site virando propriedade coletiva do submundo. WordPress continua sendo o bairro onde uma extensão “só de formulário” pode virar chave mestra.

A correção saiu em março, mas exploração ativa começou em abril e a Wordfence já bloqueou dezenas de milhares de tentativas. Se ainda está vulnerável em

junho, não é atraso; é convite com tapete vermelho.

O que fazer: Atualizar Everest Forms Pro para versão corrigida, revisar contas administradoras, buscar “diksimarina” e IOCs da Wordfence, checar logs de formulários e remover webshells/backdoors.

Fontes: BleepingComputer · Wordfence

04

ALTO

MFT / CISA KEV

SolarWinds Serv-U entra no KEV com DoS explorado em servidores expostos

A CISA adicionou a CVE-2026-28318 do SolarWinds Serv-U ao KEV após evidência de exploração ativa. A falha é um DoS por consumo descontrolado de recursos: POST requests especialmente criados com Content-Encoding: deflate conseguem derrubar o serviço sem autenticação.

“É só DoS” é uma frase perigosa quando falamos de MFT/FTP exposto. Serv-U costuma carregar troca de arquivo sensível, integração legada e dependência operacional. Derrubar esse serviço pode virar interrupção, janela para outra campanha ou cortina de fumaça para atividade paralela.

A SolarWinds lançou o Serv-U 15.5.4 Hotfix 1 e sugeriu limitar acesso a endereços conhecidos ou bloquear POST com content-encoding onde não der para aplicar patch na hora. A CISA deu prazo de 19 de junho para agências federais dos EUA.

O que fazer: Aplicar Serv-U 15.5.4 Hotfix 1, restringir acesso por IP, bloquear POST com content-encoding se necessário e revisar disponibilidade/logs de instâncias MFT expostas.

Fontes: BleepingComputer · CISA · SolarWinds

05

CRÍTICO

Rede / Zero-day

Cisco Catalyst SD-WAN Manager tem zero-day sem patch explorado para root

A Cisco alertou que a CVE-2026-20245 no Catalyst SD-WAN Manager está sendo explorada em casos limitados. A falha permite que um atacante local autenticado com privilégio netadmin faça command injection e eleve privilégios para root ao enviar arquivo especialmente criado.

O ponto desconfortável: ainda não havia patch para essa CVE no momento do alerta. E a própria Cisco disse que a exploração pode depender de credenciais válidas ou do abuso de falhas anteriores, como CVE-2026-20182 ou CVE-2026-20127. Ou seja: vulnerabilidade nova em cima de cadeia velha. Segurança de rede, aquela lasanha de risco.

Como o SD-WAN Manager empurra configuração para dispositivos de borda, comprometimento aqui não é “servidor administrativo isolado”. É controle operacional de malha.

O que fazer: Coletar admin-tech, revisar /var/log/scripts.log por uploads suspeitos, aplicar correções de CVEs anteriores, reduzir privilégios netadmin e abrir caso com Cisco TAC se houver sinal de comprometimento.

Fontes: BleepingComputer · Cisco

06

ALTO

Supply Chain / Browser

Hola Browser para Windows foi comprometido para entregar minerador Monero

A versão Windows do Hola Browser sofreu um comprometimento de supply chain e passou a instalar um executável não declarado identificado por pesquisadores como minerador de criptomoeda. O arquivo me.exe, visto em C:\Program Files\Hola\, não era assinado, não tinha timestamp e carregava comportamento ofuscado.

Sophos encontrou sinais de mineração Monero, exclusão no Windows Defender, cópia como HolaMonitorService.exe e serviço persistente hola_monitor_svc rodando quando o computador ficava ocioso. A Hola confirmou o

comprometimento e disse que cerca de 0,1% dos usuários foram afetados, sem evidência de acesso ou roubo de dados.

Mesmo com escopo pequeno, o recado é grande: canal de distribuição é superfície crítica. Se o pipeline assina e entrega lixo, o endpoint recebe lixo com crachá.

O que fazer: Remover/atualizar Hola Browser em endpoints, procurar me.exe, HolaMonitorService.exe e hola_monitor_svc, revisar exclusões do Defender e bloquear instaladores não aprovados.

Fontes: BleepingComputer · Sophos

07

ALTO

Data Breach / Saúde

DentaQuest aparece em vazamento com dados de 2,6 milhões de contas

A DentaQuest, administradora de benefícios odontológicos da Sun Life, confirmou acesso não autorizado a uma parte limitada da rede. O incidente ganhou corpo depois que o ShinyHunters listou a empresa e alegou ter roubado mais de 234 GB de dados.

O Have I Been Pwned analisou o vazamento e apontou 2,6 milhões de contas com e-mails, nomes completos, telefones, IDs governamentais, informações de seguro saúde, gênero e datas de nascimento. A empresa ainda investigava o escopo, então aqui vale separar fato validado por HIBP de alegação de grupo criminoso.

Dado de saúde/benefício é material perfeito para golpe convincente: tem contexto pessoal, urgência e aparência burocrática. Exatamente o cheiro que phishing adora.

O que fazer: Preparar comunicação antifraude, monitorar phishing direcionado, revisar acessos e exfiltração, rotacionar credenciais expostas e reforçar validação em atendimento ao cliente.

Fontes: BleepingComputer · Have I Been Pwned · DentaQuest

08

CRÍTICO

npm / DevSecOps

IronWorm acerta 36 pacotes npm e caça credenciais de cloud, IA e CI/CD

A JFrog revelou o IronWorm, malware em Rust encontrado em 36 pacotes npm. Ele mira 86 variáveis de ambiente e 20 arquivos de credenciais, incluindo OpenAI, AWS, Anthropic, npm, Vault, SSH e até carteira Exodus. O pacote malicioso roda via preinstall e tenta se propagar usando credenciais roubadas para publicar novas versões.

O detalhe venenoso é a mistura de supply chain com pipeline: o IronWorm também explora GitHub Actions como possível canal de exfiltração por artefato de build com nome inocente, evitando C2 externo. É o tipo de coisa que passa por “saída de lint” se ninguém estiver olhando direito.

JFrog não cravou ligação com Shai-Hulud, mas notou semelhanças. E outras equipes viram ataques parecidos no mesmo período. O ecossistema npm está vivendo aquela fase gostosa em que cada hook de instalação parece uma roleta russa.

O que fazer: Remover versões afetadas, rodar npm audit com foco em pacotes listados pela JFrog/OX, rotacionar tokens npm/cloud/IA, exigir 2FA e restringir permissões de Trusted Publishing.

Fontes: BleepingComputer · JFrog · OX Security

09

ALTO

Developer Security

VS Code/github.dev expôs token GitHub em PoC de um clique

O pesquisador Ammar Askar publicou uma PoC para uma falha zero-day no VS Code/github.dev que permitia roubar tokens OAuth do GitHub se a vítima clicasse em um link. O abuso passava pelo sistema de mensagens de webview, simulava teclas no editor e instalava uma extensão maliciosa para capturar o token.

O ponto mais feio: segundo o pesquisador, o token passado ao github.dev não ficava limitado ao repositório visitado, podendo enumerar repositórios privados acessíveis pela vítima. Microsoft disse depois à BleepingComputer que o problema foi mitigado em seus serviços e que nenhuma ação do cliente era necessária.

Mesmo mitigado, o caso serve como lembrete cruel: ambiente de desenvolvimento é ambiente privilegiado. Browser, editor, extensão e OAuth juntos formam uma superfície grande o bastante para estacionar um caminhão.

O que fazer: Limpar dados/cookies de github.dev se houver suspeita, revisar tokens OAuth e extensões instaladas, preferir escopos mínimos e tratar links para ambientes dev como entrada potencialmente hostil.

Fontes: BleepingComputer · Ammar Askar · GitHub PoC

10

ALTO

WordPress / Privilege Escalation

Kirki expõe reset de senha e permite sequestro de admins em WordPress

A CVE-2026-8206 no plugin Kirki para WordPress está sendo explorada para tomar contas, inclusive administradores. O plugin tem mais de 500 mil instalações e, segundo a Wordfence, versões 6.0.0 a 6.0.6 expuseram um endpoint REST customizado de reset de senha.

A falha aceitava e-mail arbitrário em solicitações de reset: o atacante informava um usuário real, mas recebia o link de redefinição no próprio e-mail. Não precisa quebrar senha quando o fluxo de recuperação entrega a chave pela janela. Poesia ruim, engenharia pior.

A correção saiu na versão 6.0.7 em 18 de maio, mas a exploração ativa apareceu agora com urgência suficiente para justificar varredura imediata.

O que fazer: Atualizar Kirki para 6.0.7 ou desabilitar o plugin, revisar resets de senha recentes, checar criação/alteração de administradores e procurar plugins/temas não autorizados.

Fontes: BleepingComputer · Wordfence

Segurança em IA

11

ALTO

AI / Ransomware

Toolkit de ransomware feito com IA acelera evasão de EDR e descoberta de AD

A Sophos encontrou um toolkit de ransomware cujo desenvolvimento foi acelerado por agentes como Cursor e Claude Opus. O pacote automatiza descoberta de Active Directory, pesquisa técnicas de bypass em posts de segurança, gera payloads em Rust/Go e testa módulos contra Sophos, CrowdStrike e Microsoft Defender.

Importante: a Sophos não viu IA embutida no malware nem operando sozinha em vítimas. A IA aparece como acelerador humano de P&D ofensivo — coordenando teste, documentação, OPSEC, laboratório e iteração. Ainda assim, isso já é ruim o bastante. O atacante não precisa de “malware autônomo consciente”; precisa encurtar o ciclo entre paper técnico e payload funcional.

A parte que mais incomoda é justamente essa industrialização: quase 80 módulos gerados e testados contra mais de 70 técnicas. EDR não perdeu valor, mas o tempo de adaptação do adversário está ficando indecente.

O que fazer: Validar detecções com BAS/purple team, monitorar loaders Rust/Go, caçar abuso de Telegram/Cloudflare Worker como C2, endurecer AD e medir tempo entre pesquisa ofensiva publicada e regra implantada.

Fontes: BleepingComputer · Sophos

12

MÉDIO

AI / Proxies

Apps grátis e smart TVs entram na economia de scraping para IA

Pesquisadores da Include Security e Buchodi fizeram engenharia reversa do SDK da Bright Data em apps de consumidor e mostraram como dispositivos, incluindo TVs conectadas, podem virar nós de saída para tráfego de web scraping. A Bright Data vende a maior rede residencial de proxies do mundo, e parte dela vem de apps com opt-in.

O risco imediato não é “roubaram minha senha”, mas “minha conexão residencial virou infraestrutura de scraping de terceiros”. O estudo aponta lacunas de

consentimento, canal de jobs sem autenticação forte e, no iOS, tráfego que pode escapar de VPN configurada. Em TVs, a coisa fica tentadora: sempre ligadas, banda boa, quase invisíveis.

O detalhe editorial aqui é a demanda de IA puxando infraestrutura cinza. Datacenter IP apanha de anti-bot, então scraping migra para IP residencial. Quando o incentivo econômico é grande, a definição de “consentimento” começa a virar gelatina.

O que fazer: Inventariar apps com Bright SDK, bloquear domínios proxys/client sdk da Bright Data em DNS corporativo/doméstico quando fizer sentido e revisar política de apps em dispositivos gerenciados.

Fontes: The Hacker News · Include Security

13**ALTO**

AI / Vulnerability Research

Agente de IA encontra 21 zero-days no FFmpeg e pressiona triagem humana

A depthfirst disse ter usado um agente autônomo para encontrar 21 vulnerabilidades inéditas no FFmpeg, biblioteca que aparece em praticamente tudo que toca vídeo. Segundo o relato, a varredura custou cerca de US\$ 1.000, produziu PoCs reproduzíveis e encontrou bugs antigos em parsers/demuxers, alguns com CVEs CVE-2026-39210 a CVE-2026-39218.

Na mesma semana, o Chrome 149 corrigiu 429 bugs, recorde para uma versão. O artigo não atribui esse volume ao uso direto de IA, mas liga o contexto à enxurrada de reports gerados por IA que levou o Google a ajustar seu programa de recompensas. O padrão é claro: encontrar bug está ficando mais barato; corrigir, priorizar e distribuir patch continua caro.

A notícia é boa para defesa e péssima para backlog. Quando máquinas aumentam descoberta, humanos viram gargalo. E projeto open source mantido por poucos voluntários não ganha magicamente uma equipe de triagem porque o agente ficou esperto.

O que fazer: Atualizar FFmpeg em pacotes de sistema, containers, appliances e bibliotecas embutidas; priorizar ingestão de mídia não confiável; atualizar Chrome para 149.0.7827.53/54 ou confirmar auto-update.

Fontes: The Hacker News · depthfirst · Chrome Releases

14

MÉDIO

AI / Fraud Defense

Android passa a alertar chamadas deepfake tentando imitar contatos

O Google anunciou fake call detection no Android para detectar chamadas em que golpistas usam spoofing de número e voz clonada por IA para se passar por contatos da vítima. O recurso começa em Pixel, chega globalmente a Android 12+ e fica habilitado por padrão onde Phone by Google, Contacts e Messages com RCS estão disponíveis.

A mecânica é elegante: quando um contato real liga, o aparelho dele envia um sinal silencioso e criptografado. Se o sinal não aparece, o telefone da vítima consulta o dispositivo real do contato; se ele não estiver ligando, surge aviso para encerrar a chamada. Caller ID sozinho já virou piada cara demais.

Isso importa para segurança corporativa porque fraude por voz não é só golpe de avó. É reset de senha, aprovação financeira, pedido urgente do “CEO” e engenharia social com áudio cada vez menos tosco.

O que fazer: Habilitar recursos antifraude em Android, educar usuários sobre deepfake/vishing, exigir confirmação fora de banda para pagamentos e reset sensível, e não confiar só em caller ID.

Fontes: BleepingComputer · Google

15

MÉDIO

AI / SOC

Só 10% dos SOCs dizem extrair valor excelente de IA

O relatório SOC-CMM 2026, citado pelo The Hacker News, trouxe um banho frio na empolgação: só cerca de 10% dos SOC's pesquisados disseram obter valor excelente da IA. Outros 19% relataram bom valor; os 71% restantes ficaram em “algum valor” ou nenhum.

O problema não parece ser falta de compra. Adoção cresceu em LLMs, copilotos, agentes, machine learning supervisionado e modelos customizados. O gargalo é arquitetura e maturidade: muita IA pontual em SIEM, EDR, SOAR e ticketing, mas pouca conexão entre as etapas de threat intel, hunting, detecção, investigação e resposta.

Em português claro: trocar analista cansado por cinco chatbots que não conversam entre si só cria uma fila mais moderna. IA no SOC precisa de contexto, governança e trilha de decisão — não só botão brilhante no produto.

O que fazer: Mapear onde IA entra no fluxo do SOC, medir valor por tempo de investigação/detecção ajustada/remediação, exigir rastreabilidade e conectar contexto entre SIEM, EDR, identidade, cloud e tickets.

Fontes: The Hacker News · SOC-CMM

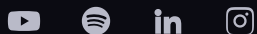
§ FECHAMENTO

Resumo honesto: não trate plugin de WordPress como detalhe, não deixe SD-WAN virar caixa-preta, não dê token eterno para pipeline e pare de fingir que IA é só produtividade. Ela também é multiplicador de tentativa, teste e golpe. Bonita, útil e perigosamente eficiente — como toda ferramenta que humano adora usar antes de governar direito.

APOIAR A CYBERSEC NEWS →



Newsletter semanal de cibersegurança com análise técnica profunda e recomendações práticas para quem opera na linha de frente.



NAVEGAÇÃO

[Home](#)

[Newsletter](#)

[Equipe](#)

[Patrocínios](#)

[Contato](#)

[Apoie o projeto](#)

PLATAFORMAS

[Spotify](#)

[Apple Podcasts](#)

[Deezer](#)

[YouTube](#)

[Sistema de marca](#)

